Projet OSINT avec OWASP Maryam

Reconnaissance passive d'une organisation publique : commandes, résultats et analyse

Projet académique réalisé en 2024 — démonstration reproduite en octobre 2026

Cible de démonstration : owasp.org (organisation publique)

---

1. Contexte et objectifs

Ce projet consiste à collecter et analyser des données publiques (infrastructure DNS, sous-domaines, adresses e-mail, profils publics, réseaux sociaux, sites web) à l'aide du framework OWASP Maryam et d'outils complémentaires, sans aucune intrusion.

Le projet a été réalisé en 2024 dans un cadre académique. Le travail d'origine n'ayant pas été conservé, ce document présente une démonstration reproduite en octobre 2026 avec la même méthodologie. Toutes les captures et tous les résultats de ce document proviennent de cette reproduction.

Objectifs

- Mettre en œuvre un framework OSINT (OWASP Maryam) et des outils complémentaires.
- Identifier ce qu'un attaquant peut apprendre d'une organisation sans aucun accès à ses systèmes.
- Relier les résultats à la matrice MITRE ATT&CK (tactique Reconnaissance).
- Formuler des recommandations pour réduire l'exposition.

2. Cadre éthique

- Collecte passive uniquement : aucun scan actif, aucune tentative d'intrusion.
- Cibles publiques ou fictives : domaine d'une organisation, adresse e-mail générique, numéro fictif (+1 202 555 0100).
- Aucune donnée personnelle de particuliers n'est publiée dans ce document.

3. Environnement de travail

Élément	Valeur
Système	Kali Linux en machine virtuelle (VMware)
Outil principal	OWASP Maryam v2.5.3
Python	3.14 (environnement virtuel venv)
Outils complémentaires	dig, whois, theHarvester 4.11.1
Cible	owasp.org
Date de la démonstration	Octobre 2026

4. Installation de Maryam

4.1 Téléchargement de Maryam et environnement virtuel

Commande(s) exécutée(s)

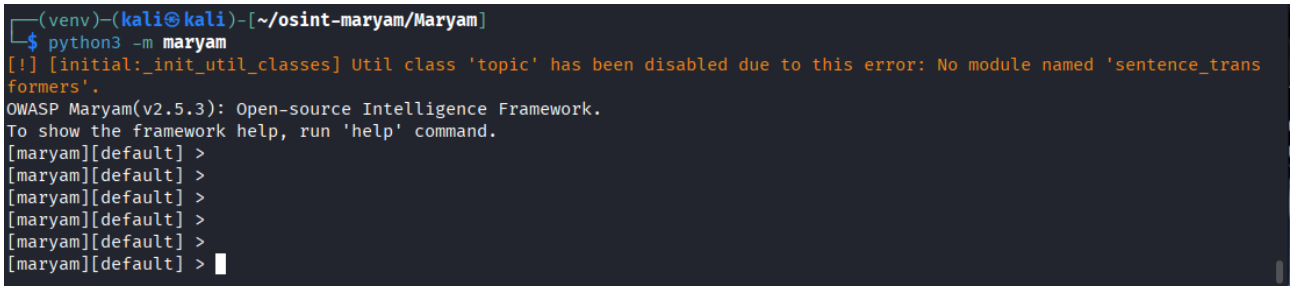
```
mkdir -p ~/osint-maryam/screenshots ~/osint-maryam/results
cd ~/osint-maryam
git clone https://github.com/saeeddhqan/Maryam.git
cd Maryam
python3 -m venv venv
source venv/bin/activate
```

Signification

mkdir crée les dossiers de travail (captures et résultats). git clone télécharge le code source de Maryam. python3 -m venv venv crée un environnement Python isolé et source venv/bin/activate l'active : l'invite affiche (venv), ce qui évite de modifier les paquets du système.

Résultat observé

Dépôt cloné et environnement virtuel activé.



Capture 1 : clonage de Maryam et activation du venv

4.2 Installation des dépendances : échec

Commande(s) exécutée(s)

```
pip install -r requirements
```

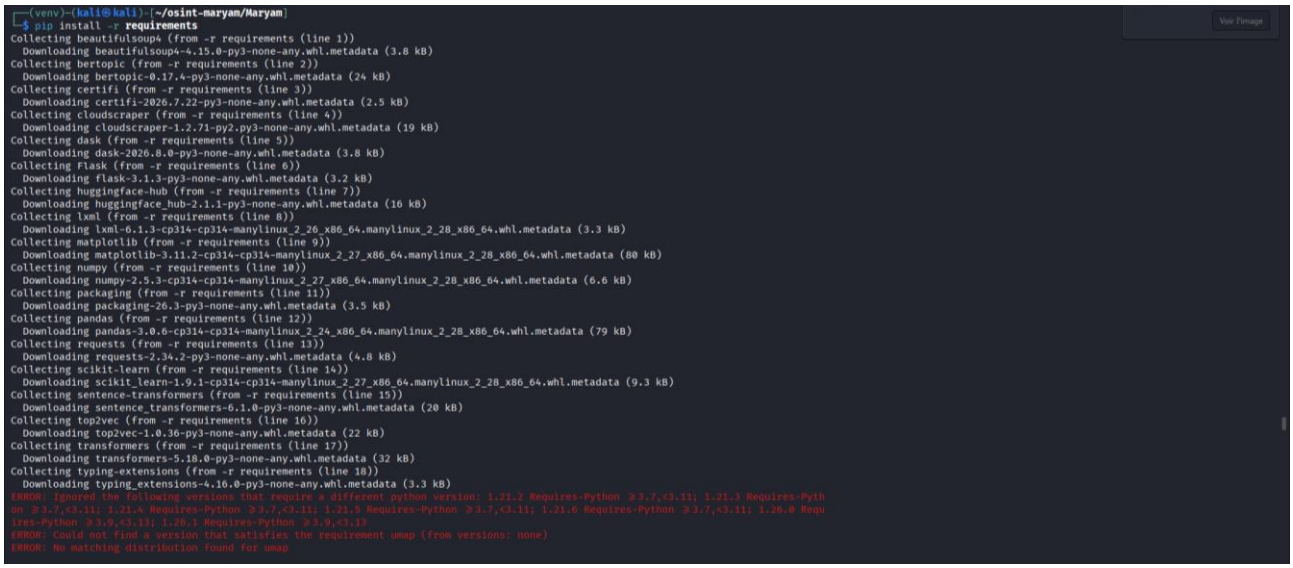
Signification

pip install -r installe toutes les bibliothèques listées dans le fichier requirements de Maryam.

Résultat observé

Échec : ERROR: No matching distribution found for umap.

Le fichier d'origine référence un paquet « umap » introuvable et de nombreuses bibliothèques de machine learning lourdes (bertopic, top2vec, transformers, sentence-transformers...) qui ne servent qu'au module de topic modeling, inutile pour la collecte OSINT.



Capture 2 : erreur « No matching distribution found for umap »

4.3 Création d'un fichier de dépendances allégé

Commande(s) exécutée(s)

```
grep -v -E '^(umap|bertopic|top2vec|sentence-transformers|transformers|huggingface-hub|scikit-learn|dask)' requirements > requirements-light.txt
cat requirements-light.txt
pip install -r requirements-light.txt
```



Capture3 : contenu du fichier « requirements-light.txt »

Signification

grep -v exclut les lignes correspondant aux paquets introuvables ou inutiles, et le résultat est enregistré dans requirements-light.txt. cat affiche son contenu, puis pip installe uniquement ces dépendances.

Résultat observé

Douze paquets conservés (beautifulsoup4, certifi, cloudscraper, Flask, lxml, matplotlib, numpy, packaging, pandas, requests, typing-extensions, vaderSentiment). Installation terminée avec le message « Successfully installed ».

```
┌──(venv)─(kali㉿kali)-[~/osint-maryam/Maryam]
└─$ pip install -r requirements-light.txt
Collecting beautifulsoup4 (from -r requirements-light.txt (line 1))
  Using cached beautifulsoup4-4.15.0-py3-none-any.whl.metadata (3.8 kB)
Collecting certifi (from -r requirements-light.txt (line 2))
  Using cached certifi-2026.7.22-py3-none-any.whl.metadata (2.5 kB)
Collecting cloudscraper (from -r requirements-light.txt (line 3))
  Using cached cloudscraper-1.2.71-py2.py3-none-any.whl.metadata (19 kB)
Collecting Flask (from -r requirements-light.txt (line 4))
  Using cached flask-3.1.3-py3-none-any.whl.metadata (3.2 kB)
Collecting lxml (from -r requirements-light.txt (line 5))
  Using cached lxml-6.1.3-cp314-cp314-manylinux_2_26_x86_64.manylinux_2_28_x86_64.whl.metadata (3.3 kB)
Collecting matplotlib (from -r requirements-light.txt (line 6))
  Using cached matplotlib-3.11.2-cp314-cp314-manylinux_2_27_x86_64.manylinux_2_28_x86_64.whl.metadata (80 kB)
Collecting numpy (from -r requirements-light.txt (line 7))
  Using cached numpy-2.5.3-cp314-cp314-manylinux_2_27_x86_64.manylinux_2_28_x86_64.whl.metadata (6.6 kB)
Collecting packaging (from -r requirements-light.txt (line 8))
  Using cached packaging-26.3-py3-none-any.whl.metadata (3.5 kB)
Collecting pandas (from -r requirements-light.txt (line 9))
  Using cached pandas-3.0.6-cp314-cp314-manylinux_2_24_x86_64.manylinux_2_28_x86_64.whl.metadata (79 kB)
Collecting requests (from -r requirements-light.txt (line 10))
  Using cached requests-2.34.2-py3-none-any.whl.metadata (4.8 kB)
Collecting typing-extensions (from -r requirements-light.txt (line 11))
  Using cached typing_extensions-4.16.0-py3-none-any.whl.metadata (3.3 kB)
Collecting vaderSentiment (from -r requirements-light.txt (line 12))
  Downloading vaderSentiment-3.3.2-py2.py3-none-any.whl.metadata (572 bytes)
Collecting soupsieve≥1.6.1 (from beautifulsoup4→-r requirements-light.txt (line 1))
  Downloading soupsieve-2.10-py3-none-any.whl.metadata (4.4 kB)
Collecting pyparsing≥2.4.7 (from cloudscraper→-r requirements-light.txt (line 3))
  Downloading pyparsing-3.3.3-py3-none-any.whl.metadata (5.9 kB)
Collecting requests-toolbelt≥0.9.1 (from cloudscraper→-r requirements-light.txt (line 3))
  Downloading requests_toolbelt-1.0.0-py2.py3-none-any.whl.metadata (14 kB)
Collecting blinker≥1.9.0 (from Flask→-r requirements-light.txt (line 4))
  Downloading blinker-1.9.0-py3-none-any.whl.metadata (1.6 kB)
Collecting click≥8.1.3 (from Flask→-r requirements-light.txt (line 4))
  Downloading click-8.5.0-py3-none-any.whl.metadata (2.6 kB)
Collecting itsdangerous≥2.2.0 (from Flask→-r requirements-light.txt (line 4))
  Downloading itsdangerous-2.2.0-py3-none-any.whl.metadata (1.9 kB)
```

Capture 4 : fichier requirements-light.txt et installation réussie

4.4 Lancement de Maryam

Commande(s) exécutée(s)

```
python3 maryam
python3 -m maryam
```

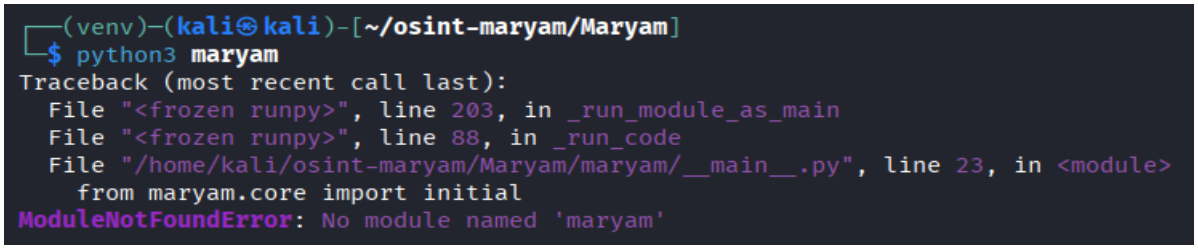
Signification

python3 maryam cherche un module nommé « maryam » et échoue. L'option -m exécute Maryam comme module Python, ce qui fonctionne.

Résultat observé

Première commande : ModuleNotFoundError: No module named 'maryam'.

Deuxième commande : le framework démarre (OWASP Maryam v2.5.3) avec un avertissement indiquant que le module « topic » est désactivé (sentence_transformers absent). Cet avertissement est sans impact sur l'OSINT.



Capture 5 : erreur ModuleNotFoundError puis démarrage de Maryam

4.5 Découverte du framework

Commande(s) exécutée(s)

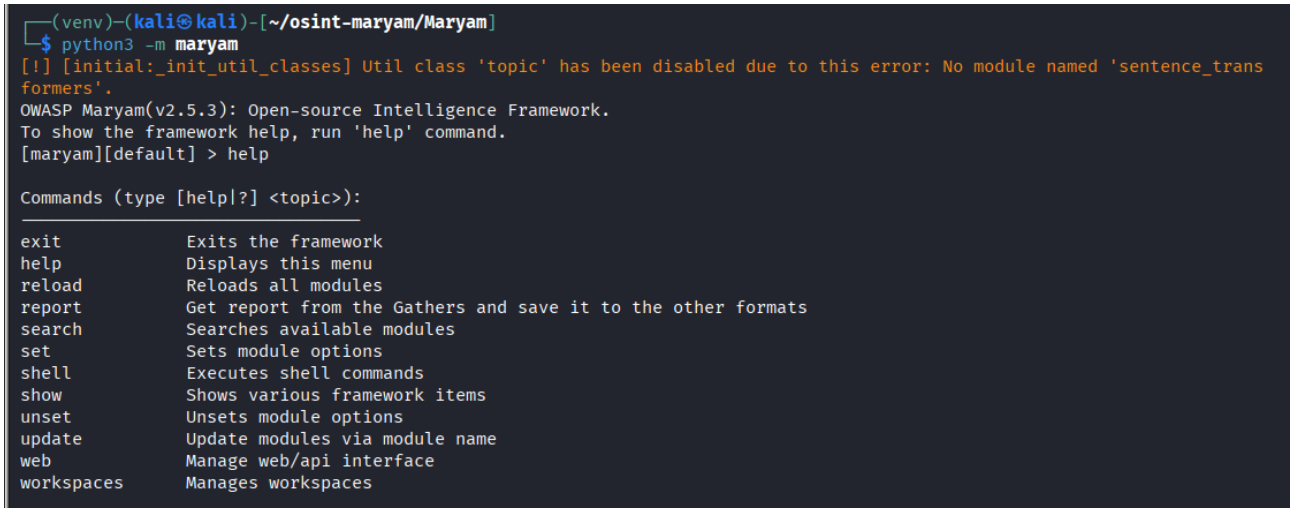
```
help
show modules
```

Signification

help liste les commandes du framework (search, set, show, workspaces, report, shell...). show modules affiche les modules par catégorie : Footprint, Search, Osint et Iris. Dans cette version, il n'y a pas de commande « use » : chaque module s'exécute directement par son nom avec ses options (on lit ses options avec l'option -h).

Résultat observé

Modules utiles pour le projet : crt, dns_search, crawl_pages, email_search, username_search, social_nets, phone_number_search, github, twitter, linkedin, duckduckgo, bing.



Capture 6 : commande help



Capture 7 : liste des modules (show modules)

4.6 Correctif de compatibilité avec Python 3.14

Commande(s) exécutée(s)

```
crt -h
crt -d owasp.org

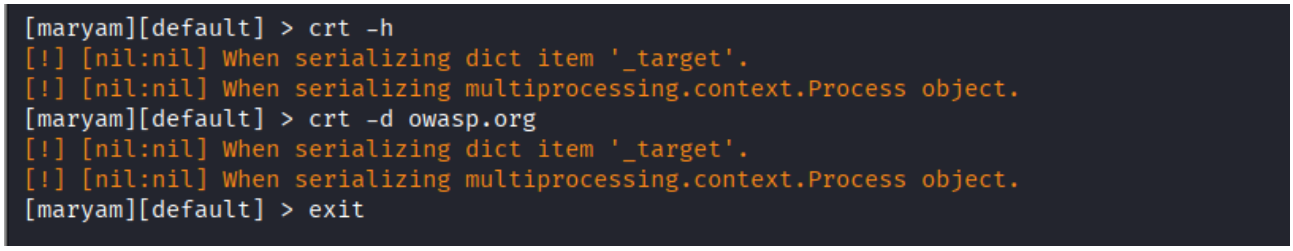
exit
sed -i '1i import multiprocessing\nmultiprocessing.set_start_method("fork", force=True)'
maryam/__main__.py
head -5 maryam/__main__.py
python3 -m maryam
crt -h
```

Signification

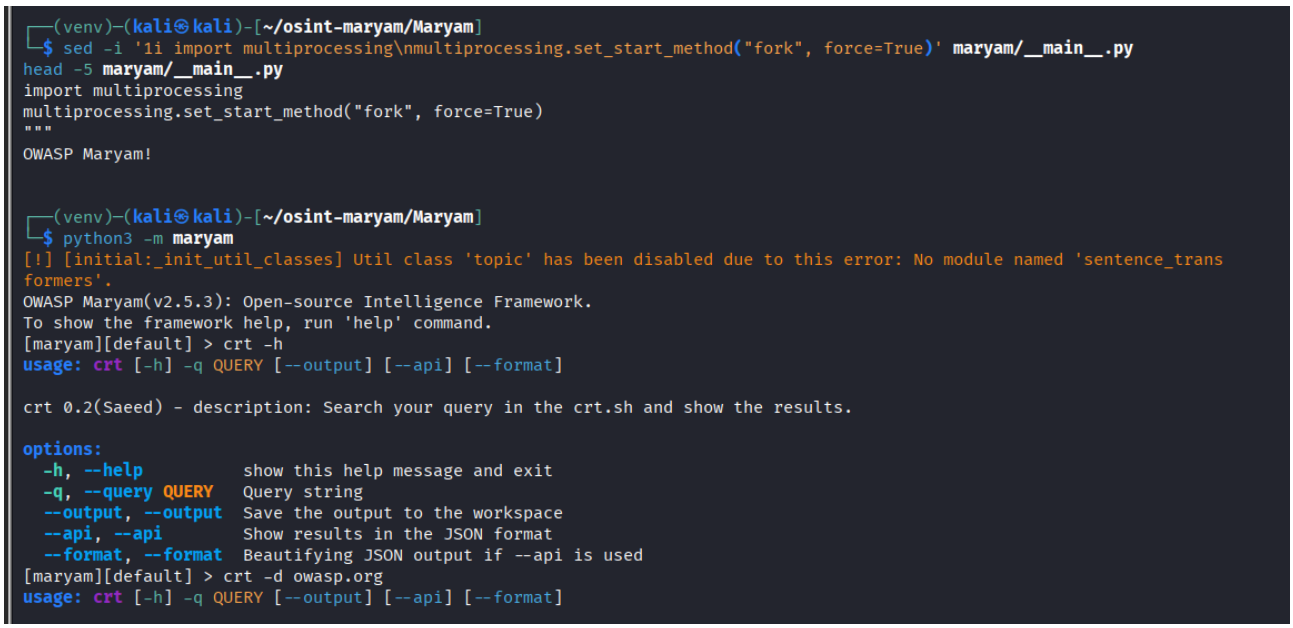
Avant le correctif, les modules échouent avec l'erreur « When serializing multiprocessing.context.Process object ». Python 3.14 a changé le mode de démarrage des processus par défaut, ce que le code ancien de Maryam ne supporte pas. La commande sed insère deux lignes au début du fichier maryam/__main__.py pour forcer l'ancien mode « fork », et head -5 vérifie l'insertion.

Résultat observé

Avant : crt -h et crt -d n'affichent que des messages d'erreur de sérialisation. Après le correctif : crt -h affiche correctement l'aide du module.



Capture 8 : erreur multiprocessing avant correctif



Capture 9 : correctif appliqué et crt -h fonctionnel

5. Dépannage réseau de la machine virtuelle

5.1 Interface réseau inactive

Commande(s) exécutée(s)

```
ping 8.8.8.8
ip -br a
sudo ip link set eth0 up
ip -br a
ping -c 2 8.8.8.8
ping -c 2 google.com
```

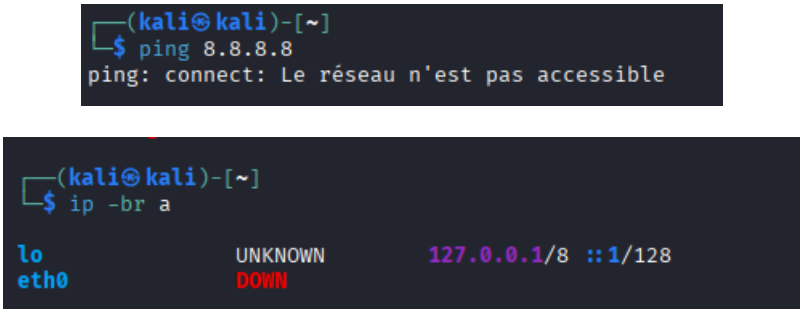
Signification

ping teste la connectivité réseau. ip -br a affiche les interfaces et leurs adresses sous forme compacte. ip link set eth0 up active l'interface réseau.

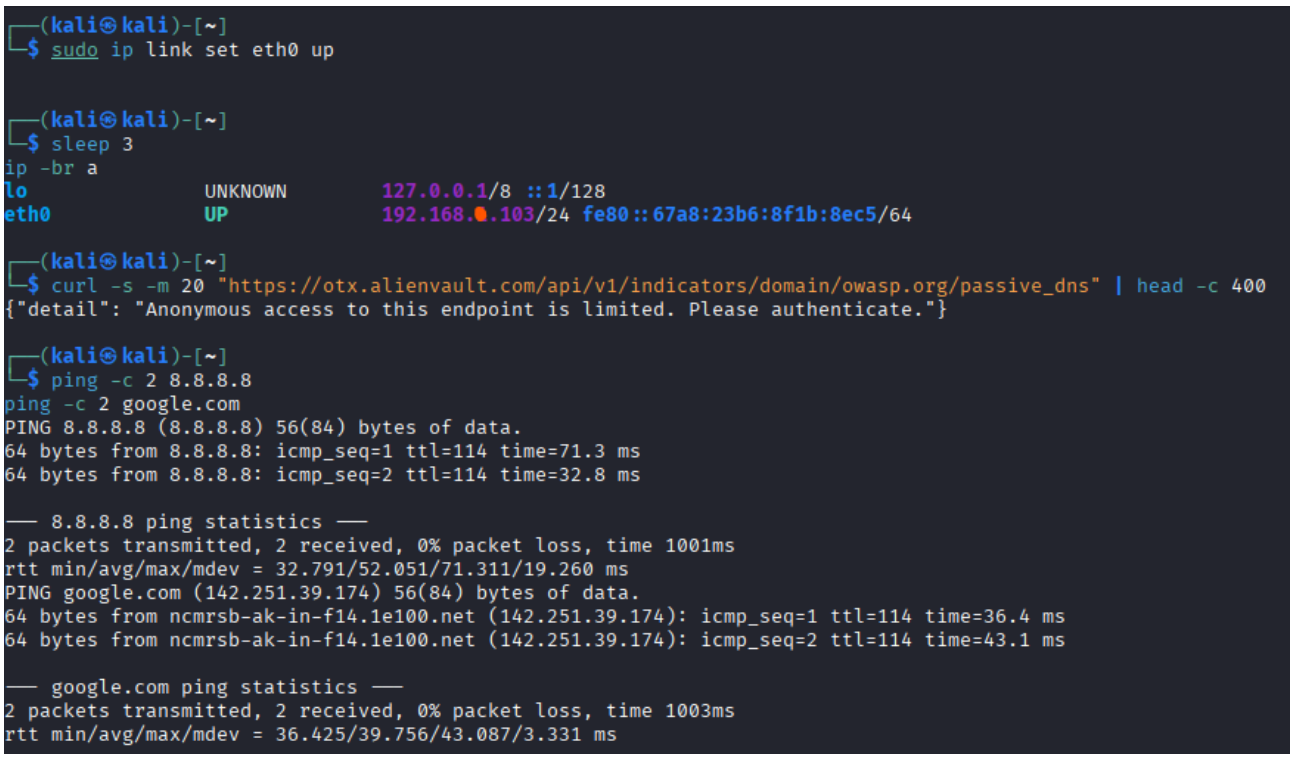
Résultat observé

Avant : « ping: connect: Le réseau n'est pas accessible » et eth0 en état DOWN sans adresse IP (VM configurée en mode Bridged).

Après activation : eth0 passe à UP avec une adresse IP, et les deux pings répondent avec 0 % de perte (connectivité et résolution DNS opérationnelles).



Capture 10 : ping en échec et eth0 DOWN



Capture 11 : eth0 UP et pings réussis

6. Collecte d'informations publiques

6.1 Sous-domaines via les certificats publics (module crt)

Commande(s) exécutée(s)

```
crt -h
crt -d owasp.org
crt -q owasp.org --output
curl -sS -m 20 "https://crt.sh/?q=owasp.org&output=json" | head -c 300
```

Signification

Le module crt interroge le service crt.sh, qui recense les certificats TLS publics, pour trouver des sous-domaines. L'option -d n'existe pas pour ce module : il utilise -q (query). --output enregistre le résultat dans le workspace. La commande curl teste directement le service pour vérifier s'il répond.

Résultat observé

crt -d : erreur « the following arguments are required: -q/--query ».

crt -q : message « CRT is missed! » et tableau de résultats vide.

curl : réponse « 502 Bad Gateway ». Conclusion : le service crt.sh était indisponible lors du test (le problème ne vient ni de Maryam ni de la machine).

```
[maryam][default] > crt -h
usage: crt [-h] -q QUERY [--output] [--api] [--format]

crt 0.2(Saeed) - description: Search your query in the crt.sh and show the results.

options:
  -h, --help          show this help message and exit
  -q, --query QUERY   Query string
  --output, --output  Save the output to the workspace
  --api, --api        Show results in the JSON format
  --format, --format  Beautifying JSON output if --api is used
[maryam][default] > crt -d owasp.org
usage: crt [-h] -q QUERY [--output] [--api] [--format]
crt: error: the following arguments are required: -q/--query
[maryam][default] > crt -q owasp.org --output
[*] [CRT] Starting Search...
[!] [util/crt:run_crawl] CRT is missed!

  +-------------------------------------------------------------------------------+
  | crt.sh ID | Logged at | Not Before | Not After | Maching Identities | Issuer Name |
  +-------------------------------------------------------------------------------+

[maryam][default] > dns_search -h
usage: dns_search [-h] -d DOMAIN [-l LIMIT] [-c COUNT] [-e ENGINES] [-t THREAD] [--max] [--validate] [--silent]
                  [-r REVERSE] [--output] [--api] [--format]

dns_search 2.5(Saeed) - description: Search in the open-sources to find subdomans.

options:
  -h, --help            show this help message and exit
  -d, --domain DOMAIN   Domain name without https?://
  -l, --limit LIMIT     Search limit(number of pages, default=3)
  -c, --count COUNT     number of results per page(min=10, max=100, default=30)
  -e, --engines ENGINES
                        Search engine names. e.g bing,google,...[otx by default]
  -t, --thread THREAD   The number of engine that run per round(default=2)
  --max, --max          Using all of sources(max limit=15, max count=50)
```

Capture 12 : aide de crt , erreur de paramètre et sans sans résultat

```
┌──(kali㉿kali)-[~]
└─$ curl -sS -m 20 "https://crt.sh/?q=owasp.org&output=json" | head -c 300
<html>
<head><title>502 Bad Gateway</title></head>
<body>
<center><h1>502 Bad Gateway</h1></center>
<hr><center>nginx</center>
</body>
</html>
```

[Capture 13 : curl crt.sh : 502 Bad Gateway — à insérer ici]

6.2 Sous-domaines via sources ouvertes (module dns_search)

Commande(s) exécutée(s)

```
dns_search -h
dns_search -d owasp.org --output
curl -s -m 20 "https://otx.alienvault.com/api/v1/indicators/domain/owasp.org/passive_dns"
| head -c 400
```

Signification

dns_search recherche des sous-domaines dans des sources ouvertes (par défaut OTX AlienVault, puis SecurityTrails). Ce module utilise l'option -d. Le curl vérifie directement la réponse du service OTX.

Résultat observé

dns_search : messages « OTX is missed! » et « Sectrails is missed! », section HOSTNAMES « Without result ».

curl OTX : « Anonymous access to this endpoint is limited. Please authenticate. » Ces sources exigent désormais un compte ou une clé API ; l'absence de résultat est donc une limite de l'accès anonyme.

```
[maryam][default] > dns_search -h
usage: dns_search [-h] -d DOMAIN [-l LIMIT] [-c COUNT] [-e ENGINES] [-t THREAD] [--max] [--validate] [--silent]
                  [-r REVERSE] [--output] [--api] [--format]

dns_search 2.5(Saeed) - description: Search in the open-sources to find subdomans.

options:
  -h, --help            show this help message and exit
  -d, --domain DOMAIN   Domain name without https?://
  -l, --limit LIMIT     Search limit(number of pages, default=3)
  -c, --count COUNT     number of results per page(min=10, max=100, default=30)
  -e, --engines ENGINES
                        Search engine names. e.g bing,google, ... [otx by default]
  -t, --thread THREAD   The number of engine that run per round(default=2)
  --max, --max          Using all of sources(max limit=15, max count=50)
  --validate, --validate
                        Validate the domains(Remove dead subdomains) found and display their IP(default=False)
  --silent, --silent    Output without any color and message([Warn]This sets the value of verbosity to zero!,
                        default=False)
  -r, --reverse REVERSE
                        Use reverse DNS search. Input could be a list of ip addresses(with comma separator) or could
                        be a filename that contains ip addresses
  --output, --output    Save the output to the workspace
  --api, --api          Show results in the JSON format
  --format, --format    Beautifying JSON output if --api is used
```

Capture 14 : aide de dns_search

```
[maryam][default] > dns_search -d owasp.org --output
[*] [OTX] Searching in otx.alienvault ...
[*] [SECTRAILS] Enumerating dns records ...
[!] [dns_search:otx] OTX is missed!
[!] [dns_search:securitytrails] Sectrails is missed!
[*] HOSTNAMES
[*]     Without result
```

Capture 15 : dns_search : sources manquantes

```
[maryam][default] > dns_search -d owasp.org --output
[*] [OTX] Searching in otx.alienvault ...
[*] [SECTRAILS] Enumerating dns records ...
[!] [dns_search:otx] OTX is missed!
[!] [dns_search:securitytrails] Sectrails is missed!
[*] HOSTNAMES
[*]     Without result

[maryam][default] > curl -s -m 20 "https://otx.alienvault.com/api/v1/indicators/domain/owasp.org/passive_dns" | head -c
400
[*] Command: curl -s -m 20 "https://otx.alienvault.com/api/v1/indicators/domain/owasp.org/passive_dns" | head -c 400

[maryam][default] > curl -s -m 20 "https://otx.alienvault.com/api/v1/indicators/domain/owasp.org/passive_dns" | head -c
400
[*] Command: curl -s -m 20 "https://otx.alienvault.com/api/v1/indicators/domain/owasp.org/passive_dns" | head -c 400

{"detail": "Anonymous access to this endpoint is limited. Please authenticate."}[maryam][default] >
[maryam][default] >
[maryam][default] >
```

Capture 16 : réponse OTX : authentification requise

6.3 Infrastructure DNS et WHOIS

Commande(s) exécutée(s)

```
dig owasp.org NS +short
dig owasp.org MX +short
dig owasp.org TXT +short
whois owasp.org | head -30
```

Signification

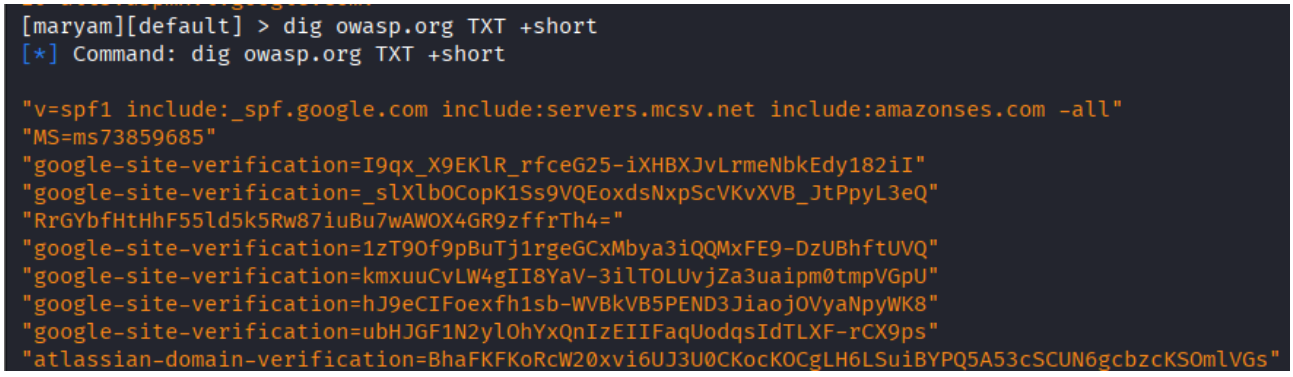
dig interroge le DNS : NS donne les serveurs de noms, MX les serveurs de messagerie, TXT les enregistrements texte (SPF, vérifications de services). L'option +short réduit l'affichage à l'essentiel. whois affiche les informations d'enregistrement du domaine.

Résultat observé

Résultats résumés dans le tableau ci-dessous.



Capture 17 : dig NS et MX



Capture 18 : dig TXT

```
[maryam][default] > whois owasp.org | head -30
[*] Command: whois owasp.org | head -30

Domain Name: owasp.org
Registry Domain ID: REDACTED
Registrar WHOIS Server: http://whois.godaddy.com
Registrar URL: http://www.whois.godaddy.com
Updated Date: 2026-08-11T23:37:38Z
Creation Date: 2001-09-21T17:00:36Z
Registry Expiry Date: 2031-09-21T17:00:36Z
Registrar: GoDaddy.com, LLC
Registrar IANA ID: 146
Registrar Abuse Contact Email: abuse@godaddy.com
Registrar Abuse Contact Phone: +1.4806242505
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientRenewProhibited https://icann.org/epp#clientRenewProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: fay.ns.cloudflare.com
Name Server: west.ns.cloudflare.com
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://icann.org/wicf/
>>> Last update of WHOIS database: 2026-10-11T17:19:43Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

Terms of Use: Access to Public Interest Registry WHOIS information is provided to assist persons in determining the cont
ents of a domain name registration record in the Public Interest Registry registry database. The data in this record is
provided by Public Interest Registry for informational purposes only, and Public Interest Registry does not guarantee it
s accuracy. This service is intended only for query-based access. You agree that you will use this data only for lawful
purposes and that, under no circumstances will you use this data to (a) allow, enable, or otherwise support the transmis
sion by e-mail, telephone, or facsimile of mass unsolicited, commercial advertising or solicitations to entities other t
han the data recipient's own existing customers; or (b) enable high volume, automated, electronic processes that send qu
eries or data to the systems of Registry Operator, a Registrar, or Identity Digital except as reasonably necessary to re
gister domain names or modify existing registrations. All rights reserved. Public Interest Registry reserves the right t
o modify these terms at any time. By submitting this query, you agree to abide by this policy.  The Registrar of Record
identified in this output may have an RDDS service that can be queried for additional information on how to contact the
Registrant, Admin, or Tech contact of the queried domain name.
```

Capture 19 : whois

Commande	Résultat observé	Interprétation
dig ... NS	fay.ns.cloudflare.com et west.ns.cloudflare.com	DNS géré par Cloudflare : l'adresse réelle des serveurs est probablement masquée.
dig ... MX	Cinq enregistrements aspmx.l.google.com et alt1 à alt4	Messagerie hébergée sur Google Workspace.
dig ... TXT	SPF incluant Google, Mailchimp (mcsv.net) et Amazon SES ; vérifications Google, Atlassian et Microsoft	Révèle les services tiers utilisés (messagerie, marketing, collaboration) : informations utiles pour du phishing ciblé.
whois	Registrar GoDaddy ; création le 2001-09-21 ; expiration le 2031-09-21 ; DNSSEC : unsigned ; contacts masqués	Domaine ancien dont les données personnelles sont masquées ; DNSSEC non activé.

Remarque : la commande whois a affiché « Temps limite dépassé » en fin de sortie, sans conséquence sur les informations obtenues.

6.4 Sous-domaines, IP et URLs avec theHarvester

Commande(s) exécutée(s)

```
sudo apt install -y theharvester
theHarvester -d owasp.org -b duckduckgo -l 50
theHarvester -h
mkdir -p ~/osint-maryam/results
theHarvester -d owasp.org -b rapiddns,hackertarget,urlscan,yahoo,brave -l 100 -q -f
~/osint-maryam/results/harvester_owasp
```

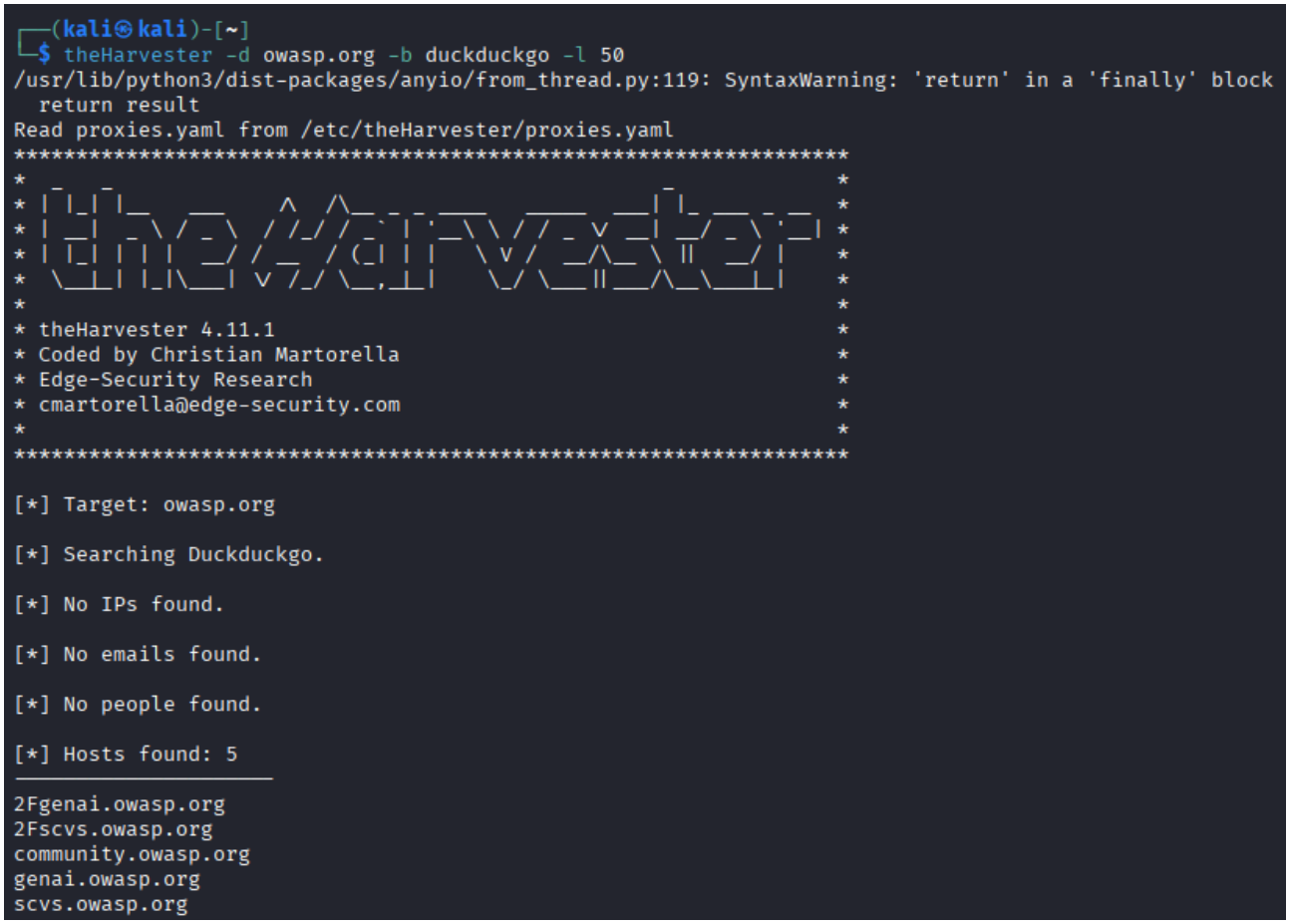
Signification

theHarvester collecte hôtes, adresses IP, e-mails et URLs à partir de sources publiques. Options : -d pour le domaine, -b pour les sources, -l pour la limite de résultats, -q pour masquer les avertissements de clés API manquantes, -f pour exporter les résultats en JSON et XML.

Résultat observé

Avec DuckDuckGo seul : 5 hôtes trouvés, aucune IP, aucun e-mail. Deux faux positifs (2Fgenai.owasp.org et 2Fscvs.owasp.org) dus à l'encodage d'URL (%2F), écartés lors du nettoyage : il reste trois sous-domaines réels (community, genai, scvs).

Avec plusieurs sources sans clé API : 127 entrées hôte:IP, 11 adresses IP, 3 ASN (AS13335, AS15169, AS16509), 12 URLs intéressantes, aucun e-mail. La source brave a échoué (clé API manquante). Résultats exportés dans harvester_owasp.json et harvester_owasp.xml.



Capture 20 : theHarvester avec DuckDuckGo

```
┌──(kali㉿kali)-[~]
└─$ theHarvester -h
/usr/lib/python3/dist-packages/anyio/from_thread.py:119: SyntaxWarning: 'return' in a 'finally' block
  return result
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*******************************************************************
*  _   _                                            _              *
* | |_| |__   ___    /\  /\__ _ _ ____   _____  ___| |_ ___ _ __   *
* | __|  _ \ / _ \  / /_/ / _` | '__\ \ / / _ \/ __| __/ _ \ '__|  *
* | |_| | | |  __/ / __  / (_| | |   \ V /  __/\__ \ ||  __/ |     *
*  \__|_| |_|\___| \/ /_/ \__,_|_|    \_/ \___||___/\__\___|_|     *
*                                                                  *
* theHarvester 4.11.1                                              *
* Coded by Christian Martorella                                    *
* Edge-Security Research                                           *
* cmartorella@edge-security.com                                    *
*                                                                  *
*******************************************************************
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-S START] [-p] [-s] [--screenshot SCREENSHOT] [-e DNS_SERVER] [-t] [-r [DNS_RESOLVE]]
                    [-n] [-c] [-f FILENAME] [-w WORDLIST] [-a] [-q] [-b SOURCE]

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
  -h, --help            show this help message and exit
  -d, --domain DOMAIN   Company name or domain to search.
  -l, --limit LIMIT     Limit the number of search results, default=500.
  -S, --start START     Start with result number X, default=0.
  -p, --proxies         Use proxies for requests, enter proxies in proxies.yaml.
  -s, --shodan          Use Shodan to query discovered hosts.
  --screenshot SCREENSHOT
                        Take screenshots of resolved domains specify output directory: --screenshot output_directory
  -e, --dns-server DNS_SERVER
                        DNS server to use for lookup.
  -t, --take-over       Check for takeovers.
  -r, --dns-resolve [DNS_RESOLVE]
                        Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False.
  -n, --dns-lookup      Enable DNS server lookup, default False.
  -c, --dns-brute       Perform a DNS brute force on the domain.
  -f, --filename FILENAME
                        Save the results to an XML and JSON file.
  -w, --wordlist WORDLIST
                        Specify a wordlist for API endpoint scanning.
  -a, --api-scan        Scan for API endpoints.
  -q, --quiet           Suppress missing API key warnings and reading the api-keys file.
  -b, --source SOURCE   baidu, bevigil, bitbucket, brave, bufferoverun, builtwith, censys, certspotter, chaos, commoncrawl,
```

Capture 21 : aide de theHarvester (-h)

```
┌──(kali㉿kali)-[~]
└─$ theHarvester -d owasp.org -b rapiddns,hackertarget,urlscan,yahoo,brave -l 100 -q -f ~/osint-maryam/results/harvester_owasp
/usr/lib/python3/dist-packages/anyio/from_thread.py:119: SyntaxWarning: 'return' in a 'finally' block
  return result
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*******************************************************************
*  _   _                                            _              *
* | |_| |__   ___    /\  /\__ _ _ ____   _____  ___| |_ ___ _ __   *
* | __|  _ \ / _ \  / /_/ / _` | '__\ \ / / _ \/ __| __/ _ \ '__|  *
* | |_| | | |  __/ / __  / (_| | |   \ V /  __/\__ \ ||  __/ |     *
*  \__|_| |_|\___| \/ /_/ \__,_|_|    \_/ \___||___/\__\___|_|     *
*                                                                  *
* theHarvester 4.11.1                                              *
* Coded by Christian Martorella                                    *
* Edge-Security Research                                           *
* cmartorella@edge-security.com                                    *
*                                                                  *
*******************************************************************

[*] Target: owasp.org

Failed to process brave search for word: 'owasp.org'
Error Message:
[!] Missing API key for Brave Search.
[*] Searching Urlscan.
[*] Searching Hackertarget.
[*] Searching Rapiddns.
[*] Searching Yahoo.

[*] ASNS found: 3
--------------------
AS13335
AS15169
AS16509

[*] Interesting Urls found: 12
------------------------------
https://cheatsheetseries.owasp.org/
https://community.owasp.org/
https://community.owasp.org/attacks/xss/
https://community.owasp.org/vulnerabilities/
https://owasp.org/
https://owasp.org/index.php/TLS/SSLCipher_Hardening
https://owasp.org/index.php/Transport_Layer_Protection_Cheat_Sheet
https://owasp.org/projects/secure-coding-practices
```

Capture 22 : theHarvester multi-sources : ASN, URLs, IP

```
https://owasp.org/projects/secure-coding-practices
https://owasp.org/projects/top-10-for-large-language-model-applications
https://owasp.org/projects/top-10-for-large-language-model-applications/Archive/0_1_vulns/Prompt_Injection.html
https://owasp.org/projects/web-security-testing-guide/latest/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server
https://wstg.owasp.org/

[*] IPs found: 11
-----------------
104.20.[redacted].163
172.66.[redacted].115
216.150.[redacted].129
216.150.[redacted].193
216.150.[redacted].65
216.150.[redacted].1
216.150.[redacted].193
216.150.[redacted].65
2606:4700:10::6814:2ca3
2606:4700:10::ac42:9d73
2a00:1450:4001:c15::84

[*] No emails found.

[*] No people found.

[*] Hosts found: 127
--------------------
20thanniversary.owasp.org:104.20.[redacted].163
20thanniversary.owasp.org:172.66.[redacted].115
20thanniversary.owasp.org:2606:4700:10::6814:2ca3
20thanniversary.owasp.org:2606:4700:10::ac42:9d73
20thanniversary.owasp.org:8.47.[redacted].0
20thanniversary.owasp.org:8.6.[redacted].0
aghast.owasp.org:185.199.[redacted].153
aivss.owasp.org:172.66.[redacted].115
aos.owasp.org:104.20.[redacted].163
asvs.owasp.org:104.20.[redacted].163
austin.owasp.org:104.20.[redacted].163
austin.owasp.org:172.66.[redacted].115
austin.owasp.org:2606:4700:10::6814:2ca3
austin.owasp.org:2606:4700:10::ac42:9d73
blt.owasp.org:104.20.[redacted].163
board.owasp.org:172.66.[redacted].115
brainbreak.owasp.org:104.20.[redacted].163
brainbreak.owasp.org:172.66.[redacted].115
brainbreak.owasp.org:2606:4700:10::6814:2ca3
brainbreak.owasp.org:2606:4700:10::ac42:9d73
```

```
secureflag.owasp.org:inbound-smtp.eu-west-1.amazonaws.com
securitychampions.owasp.org:104.20.[redacted].163
sl.owasp.org:104.20.[redacted].163
sl.owasp.org:172.66.[redacted].115
sl.owasp.org:2606:4700:10::6814:2ca3
sl.owasp.org:2606:4700:10::ac42:9d73
support.docs.owasp.org:18.164.[redacted].93
support.owasp.org:13.35.[redacted].21
top10proactive.owasp.org:172.66.[redacted].115
training.owasp.org:172.66.[redacted].115
training.owasp.org:2606:4700:10::6814:2ca3
training.owasp.org:2606:4700:10::ac42:9d73
videos.owasp.org:104.20.[redacted].163
videos.owasp.org:172.66.[redacted].115
videos.owasp.org:2606:4700:10::6814:2ca3
videos.owasp.org:2606:4700:10::ac42:9d73
wiki.owasp.org:104.20.[redacted].163
wiki.owasp.org:167.99.[redacted].52
wiki.owasp.org:172.66.[redacted].115
wiki.owasp.org:2606:4700:10::6814:2ca3
wiki.owasp.org:2606:4700:10::ac42:9d73
wstg.owasp.org
www2.owasp.org:2606:4700:10::6814:2ca3
www2.owasp.org:2606:4700:10::ac42:9d73

[*] Reporting started.
[*] XML File saved.
[*] JSON File saved.
```

Capture 23 : theHarvester : liste des hôtes et export JSON/XML

Analyse des résultats de theHarvester

- ASN : AS13335 (Cloudflare), AS15169 (Google) et AS16509 (Amazon) : l'infrastructure est répartie chez plusieurs fournisseurs.
- La majorité des sous-domaines résolvent vers des adresses Cloudflare (104.20.44.163, 172.66.157.115 et leurs équivalents IPv6) : l'adresse réelle des serveurs est masquée.
- Quelques sous-domaines (par exemple cloud, wiki, lists, name-virt-host, giving, secureflag) résolvent vers des adresses hors Cloudflare : leur serveur d'origine est visible publiquement, ce qui élargit la surface d'attaque exposée.

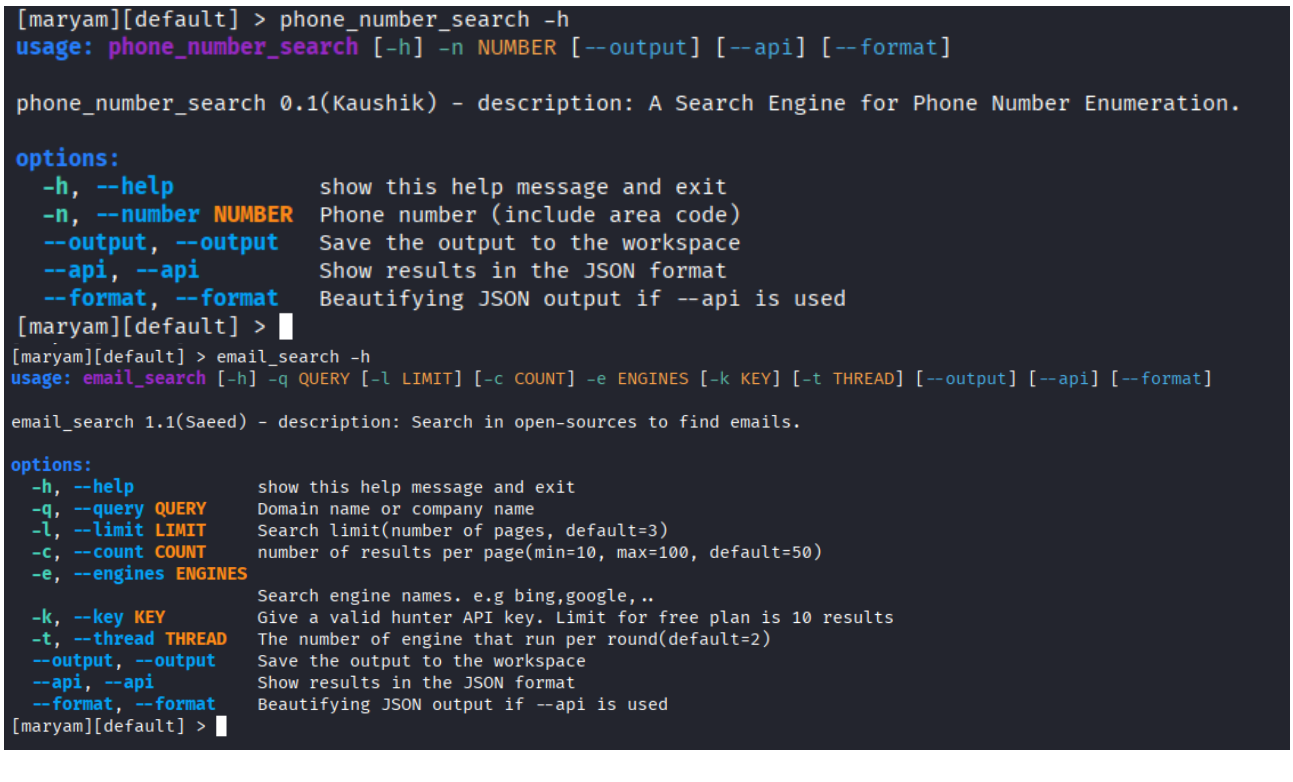
- Les noms de sous-domaines (dev, mail, wiki, lists, members, gapps) renseignent un attaquant sur les services utilisés.
- Aucune adresse e-mail trouvée avec ces sources : résultat à relativiser, car les sources gratuites utilisées sont limitées.

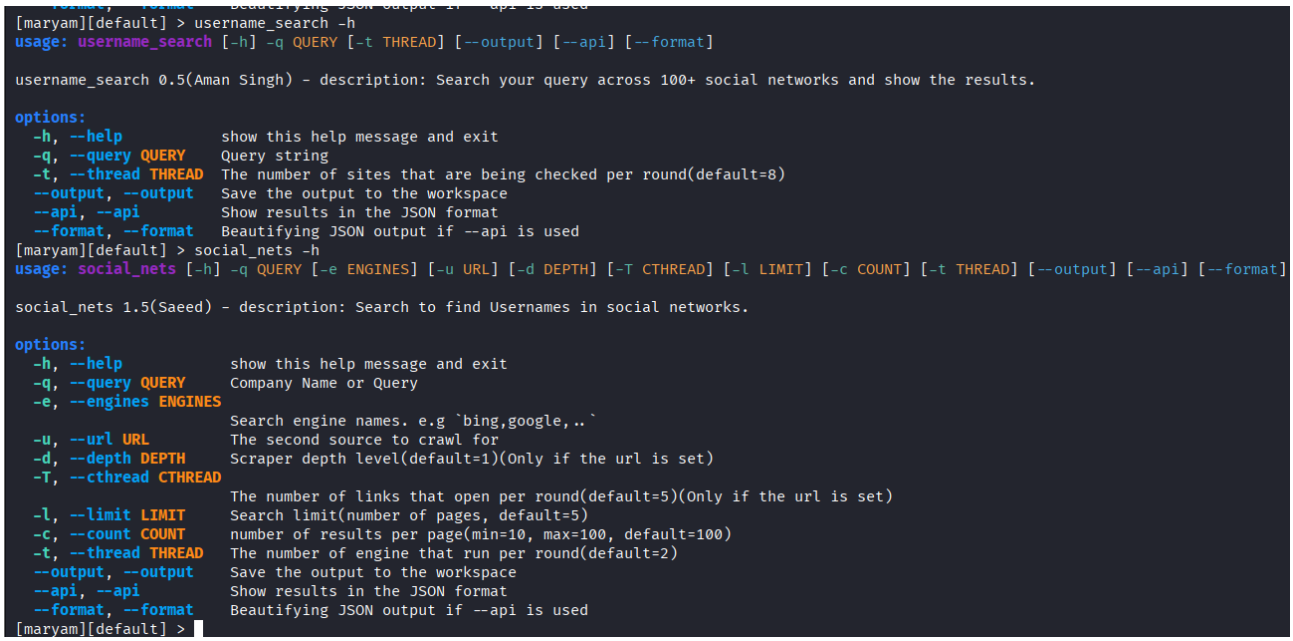
7. E-mails, profils publics et réseaux sociaux (modules Maryam)

Cette partie correspond au cœur de la ligne du CV : collecte et analyse d'adresses e-mail, de profils publics, de réseaux sociaux et de sites web. Les cibles utilisées sont uniquement des éléments génériques d'organisation : le domaine owasp.org, le nom d'utilisateur « owasp » et un numéro fictif (+1 202 555 0100).

Commandes à exécuter (lecture de l'aide de chaque module en premier)

```
email_search -h
username_search -h
social_nets -h
```





Capture 24 : aide des modules email_search, username_search, social_nets, phone_number_search

7.1 Adresses e-mail (module email_search)

Commande(s) exécutée(s)

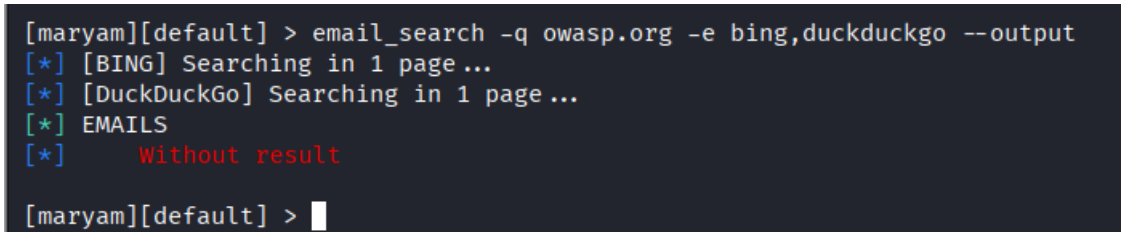
```
email_search -q owasp.org -e bing,duckduckgo --output
```

Signification

Le module cherche des adresses e-mail liées au domaine dans les moteurs de recherche indiqués avec -e. --output enregistre le résultat dans le workspace.

Résultat observé

Section EMAILS : « Without result ». Aucune adresse e-mail publique n'a été trouvée avec ces deux moteurs, ce qui est cohérent avec le résultat de theHarvester. Résultat à relativiser : les moteurs gratuits limitent les requêtes automatisées.



Capture 25 : email_search : aucun résultat

7.2 Profils publics (module username_search)

Commande(s) exécutée(s)

```
username_search -q owasp --output
```

Signification

Le module teste si le nom d'utilisateur « owasp » existe sur plus de 100 réseaux et plateformes, en vérifiant l'adresse du profil sur chaque site. Les résultats sont triés par popularité du site.

Résultat observé

L'outil affiche « Found 82 accounts » avec, pour chacun, le site et l'adresse du profil.

Les plateformes concernées sont variées : réseaux sociaux (Reddit, Mastodon, Facebook, VK, Tumblr, Pinterest), plateformes de code (GitHub, Gitee, PyPI, dev.to), partage de médias et de présentations (Vimeo, DailyMotion, SoundCloud, Flickr, Slideshare), forums et autres services.

```
[maryam][default] > username_search -q owasp --output
Found 82 accounts

[*] Accounts Found (sorted by site's rank)

+-------------+-----------------------------------------------+
|    Site     |                    Account                    |
+-------------+-----------------------------------------------+
| Pinterest   | https://www.pinterest.com/owasp/              |
+-------------+-----------------------------------------------+
| Wikipedia   | https://en.wikipedia.org/wiki/User:owasp      |
+-------------+-----------------------------------------------+
| VK          | https://vk.com/owasp                          |
+-------------+-----------------------------------------------+
| Vimeo       | https://vimeo.com/owasp                       |
+-------------+-----------------------------------------------+
| Reddit      | https://www.reddit.com/user/owasp             |
+-------------+-----------------------------------------------+
| SoundCloud  | https://soundcloud.com/owasp                  |
+-------------+-----------------------------------------------+
| Flickr      | https://www.flickr.com/photos/owasp/          |
+-------------+-----------------------------------------------+
| Slideshare  | https://www.slideshare.net/owasp              |
+-------------+-----------------------------------------------+
```

Capture 26 : username_search : début de la liste des comptes trouvés (82 comptes)

Limites de ce résultat

- Le module vérifie seulement l'existence d'une page au nom « owasp » : un compte portant ce nom n'appartient pas forcément à l'organisation OWASP. Une vérification manuelle serait nécessaire pour confirmer les comptes officiels.
- Des doublons apparaissent (dev.to listé deux fois, ainsi que Trakt, Championat, Gitee et Designspiration), donc le chiffre de 82 est surévalué.
- Certaines lignes ne sont que des adresses de recherche, et non des profils confirmés (par exemple l'entrée ProtonMail, qui interroge l'adresse owasp@protonmail.com).
- Par prudence, la liste complète des adresses de profils n'est pas reproduite dans ce document.

7.3 Réseaux sociaux (module social_nets)

Commande(s) exécutée(s)

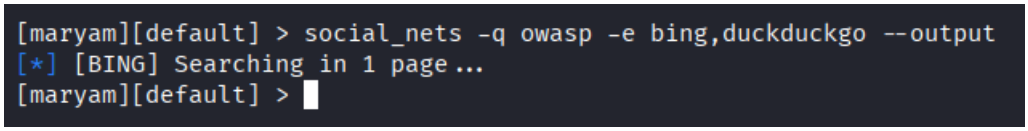
```
social_nets -q owasp -e bing,duckduckgo --output
```

Signification

Le module cherche des noms d'utilisateur sur les réseaux sociaux à partir de moteurs de recherche (option -e). La commande a été lancée deux fois.

Résultat observé

Seule la ligne « [BING] Searching in 1 page... » s'affiche, puis l'invite revient sans aucune liste de résultats, aux deux essais. Aucun résultat exploitable : les moteurs ont probablement bloqué ou limité les requêtes automatisées. Cette limite est notée dans la section 11.



Capture 27 : social_nets : exécution sans résultat affiché

7.4 Numéro de téléphone fictif (module phone_number_search)

Commande(s) exécutée(s)

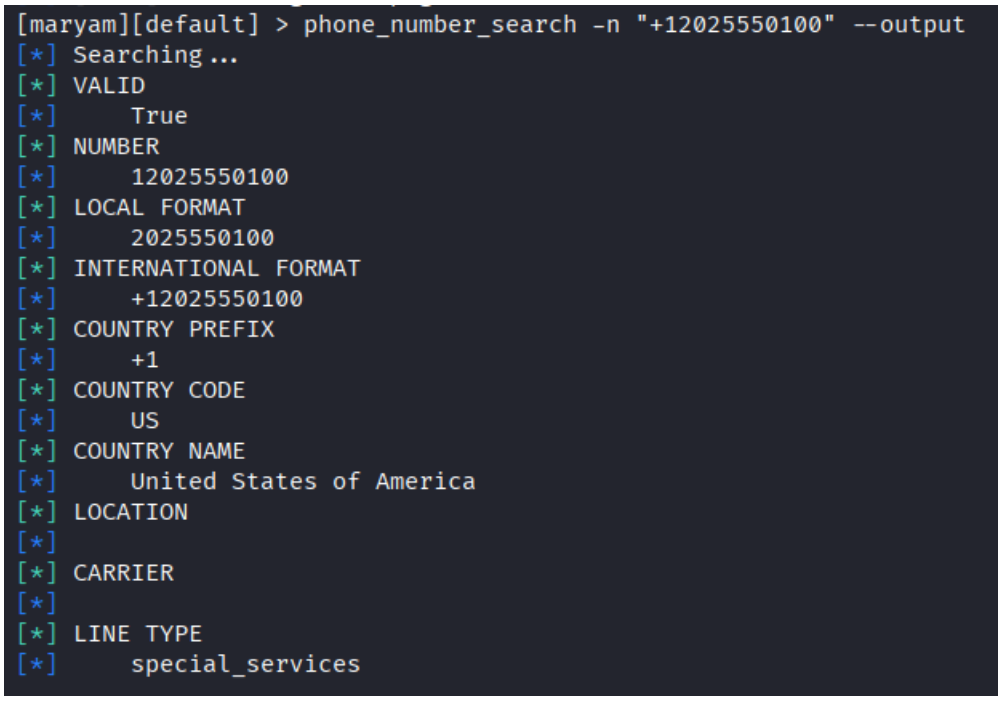
```
phone_number_search -n "+12025550100" --output
```

Signification

Le module analyse un numéro de téléphone : validité, format, pays, opérateur et type de ligne. Le numéro utilisé est fictif (la plage 555-01XX est réservée aux exemples), donc aucune donnée personnelle n'est concernée.

Résultat observé

VALID : True. Formats : 2025550100 (local) et +12025550100 (international). Préfixe +1, pays US (United States of America). Localisation et opérateur : non renseignés. Type de ligne : special_services. Le module vérifie surtout le format et le plan de numérotation ; il ne révèle aucune information sur un propriétaire.



Capture 28 : phone_number_search : résultat pour le numéro fictif

8. Amélioration : automatisation de la collecte DNS et WHOIS

Pour éviter de retaper les commandes à la main, un script Bash (osint_recon.sh, fourni en annexe) automatise la collecte passive : enregistrements DNS NS, MX, TXT et A, extrait WHOIS, puis indicateurs de sécurité (présence de SPF, DMARC et DNSSEC). Il génère un rapport Markdown horodaté dans le dossier results.

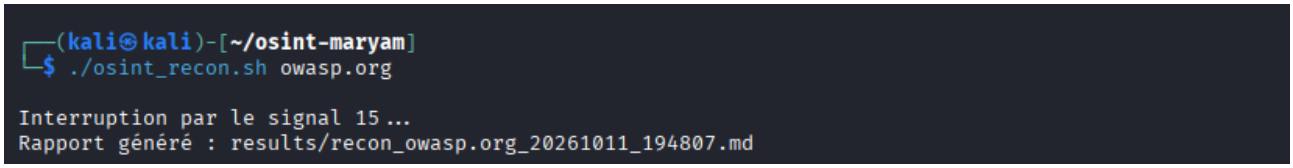
Commande(s) exécutée(s)

```
nano osint_recon.sh
```

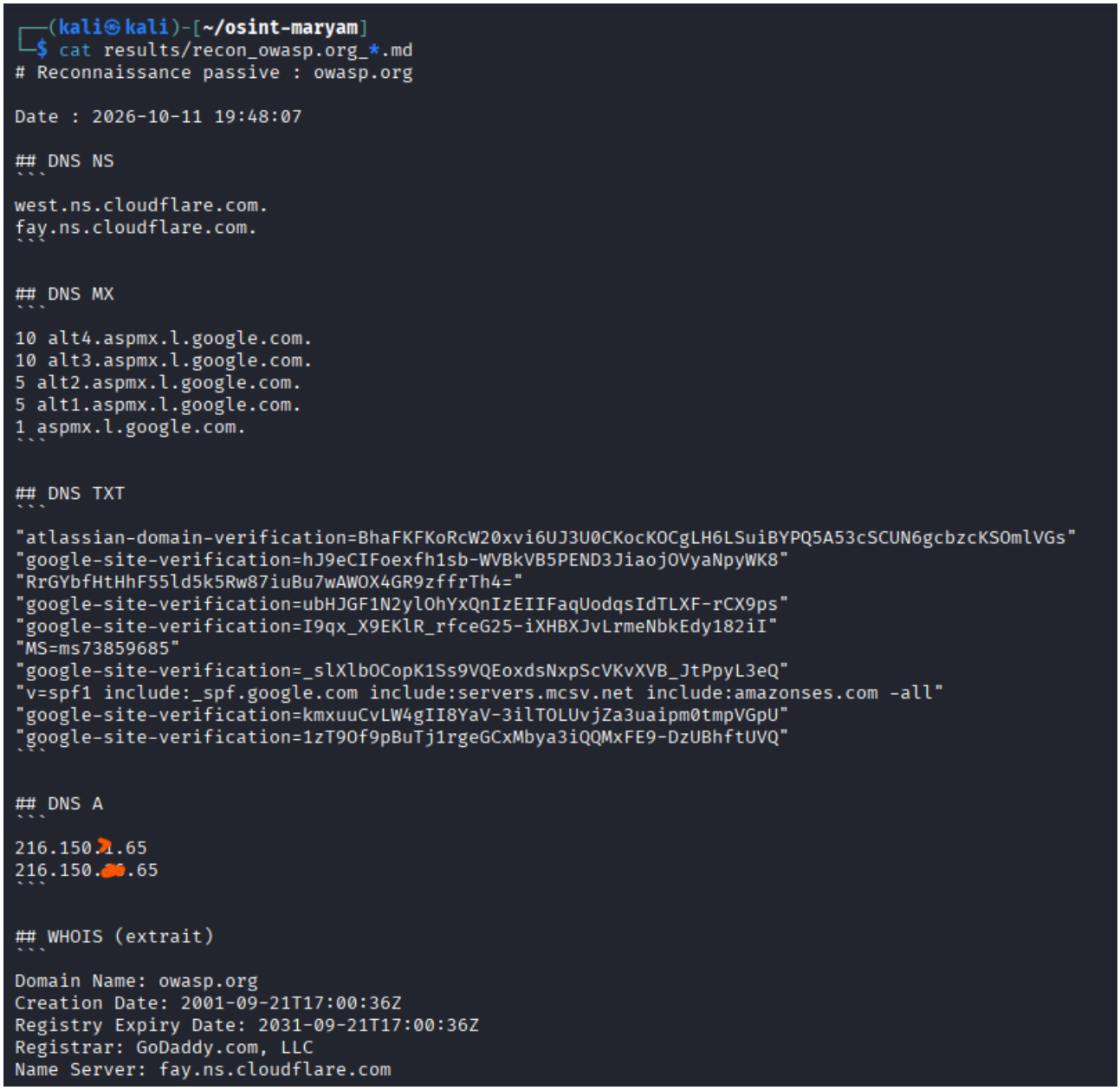
```
chmod +x osint_recon.sh
./osint_recon.sh owasp.org
cat results/recon_owasp.org_*.md
```

Signification

nano permet de créer le fichier du script. chmod +x donne au fichier le droit d'être exécuté (sans cela, Kali répond « Permission denied »). Le préfixe ./ lance le script situé dans le dossier courant, avec owasp.org comme argument. cat affiche le rapport généré.



Capture 29 : exécution de ./osint_recon.sh owasp.org



Capture 30 : contenu du rapport généré

9. Analyse et mapping MITRE ATT&CK

Les actions réalisées correspondent à la tactique TA0043 (Reconnaissance) :

Technique	Lien avec le projet
T1590.002 — Gather Victim Network Information : DNS	Commandes dig NS, MX, TXT ; module dns_search
T1596.002 — Search Open Technical Databases : WHOIS	Commande whois
T1589.002 — Gather Victim Identity Information : Email Addresses	email_search, theHarvester
T1593.001 — Search Open Websites/Domains : Social Media	social_nets, username_search

10. Observations et recommandations

Constats

- Technologies tierces identifiables publiquement (Google Workspace, Mailchimp, Amazon SES, Atlassian, Microsoft), informations pouvant faciliter une attaque d'ingénierie sociale.
- DNSSEC non activé sur le domaine.
- Plusieurs sous-domaines résolvent vers des adresses hors Cloudflare.

pistes d'amélioration générales

- Activer DNSSEC sur le domaine.
- Vérifier la présence et la configuration de SPF, DKIM et DMARC.
- Placer les sous-domaines exposés derrière le service de protection ou restreindre l'accès direct à leur serveur d'origine.
- Supprimer les enregistrements TXT de vérification devenus inutiles.
- Sensibiliser les utilisateurs au phishing.

11. Limites et difficultés rencontrées

- crt.sh indisponible lors des tests (502 Bad Gateway).
- OTX AlienVault et SecurityTrails : accès anonyme refusé, clé API nécessaire.
- Source brave de theHarvester : clé API manquante.
- Incompatibilité de Maryam (code ancien) avec Python 3.14 : correctif appliqué (section 4.6).
- Dépendances de machine learning introuvables ou trop lourdes : installation allégée (sections 4.2 et 4.3).
- Interface réseau de la VM inactive: remise en service avec ip link set eth0 up (section 5).
- Aucune adresse e-mail trouvée : sources gratuites limitées, résultat à relativiser.

12. Conclusion

Ce projet montre qu'il est possible de dresser un portrait précis de l'infrastructure d'une organisation uniquement à partir de sources publiques : fournisseurs DNS et de messagerie, services tiers utilisés, sous-domaines et adresses exposées. Il illustre aussi l'importance de la démarche de dépannage (compatibilité, dépendances, indisponibilité de services) et de la documentation honnête des limites.

Compétences mises en œuvre

OSINT, reconnaissance passive, DNS et WHOIS, Linux (Kali), Python (environnement virtuel, dépannage de dépendances), Bash, MITRE ATT&CK, rédaction de rapport.

Annexe : script osint_recon.sh

Usage : ./osint_recon.sh owasp.org (prérequis : dig et whois, paquets dnsutils et whois).

```
#!/usr/bin/env bash
# osint_recon.sh - Reconnaissance passive automatisée (DNS + WHOIS)
# Usage : ./osint_recon.sh owasp.org
# Prérequis : dig (dnsutils), whois
# Passif uniquement : aucune requête intrusive sur la cible.

set -u

DOMAIN="${1:-}"
if [ -z "$DOMAIN" ]; then
  echo "Usage : $0 domaine.tld"
  exit 1
fi

for cmd in dig whois; do
  if ! command -v "$cmd" >/dev/null 2>&1; then
    echo "Erreur : '$cmd' n'est pas installé (sudo apt install dnsutils whois)"
    exit 1
  fi
done

mkdir -p results
OUT="results/recon_${DOMAIN}_$(date +%Y%m%d_%H%M%S).md"

SPF=$(dig +short TXT "$DOMAIN" | grep -c 'v=spf1')
DMARC=$(dig +short TXT "_dmarc.${DOMAIN}" | grep -c 'v=DMARC1')
DNSKEY=$(dig +short DNSKEY "$DOMAIN" | wc -l)

{
  echo "# Reconnaissance passive : ${DOMAIN}"
  echo
  echo "Date : $(date '+%Y-%m-%d %H:%M:%S')"
  echo

  for t in NS MX TXT A; do
    echo "## DNS ${t}"
    echo '```'
    dig +short "$DOMAIN" "$t"
    echo '```'
    echo
  done

  echo "## WHOIS (extrait)"
  echo '```'
  timeout 30 whois "$DOMAIN" | grep -E -i '^(Domain Name|Registrar:|Creation
Date|Registry Expiry Date|Name Server|DNSSEC)'
  echo '```'
  echo

  echo "## Indicateurs de sécurité"
  if [ "$SPF" -gt 0 ]; then echo "- SPF : présent"; else echo "- SPF : ABSENT (risque
d'usurpation d'e-mail)"; fi
  if [ "$DMARC" -gt 0 ]; then echo "- DMARC : présent"; else echo "- DMARC : ABSENT (pas
de politique anti-usurpation)"; fi
  if [ "$DNSKEY" -gt 0 ]; then echo "- DNSSEC : activé"; else echo "- DNSSEC : non
activé"; fi
```

```
  echo
  echo "Mapping MITRE ATT&CK : TA0043 Reconnaissance (T1590.002, T1596.002)"
} > "$OUT"

echo "Rapport généré : $OUT"
```